

Grafos de Conhecimento Centrados em Sessão HTTP para Detecção Explicável de DDoS

Natanael Oliveira^{a,*}, Arthur Kobielski^a, Marcos Luna^a

^a *Universidade Federal do Rio Grande do Sul, Porto Alegre, Brasil*

Abstract

Ataques distribuídos de Slow HTTP DoS sustentam taxas baixas por sessão e atravessam defesas baseadas em assinatura, limiares estatísticos e quotas por IP, sessão ou *token*. O sinal de ataque não está em nenhuma sessão isolada, mas na correlação estrutural entre sessões coordenadas. A literatura de detecção reduz a sessão a um vetor numérico antes do classificador e descarta essa estrutura. Trabalhos recentes combinam grafos de conhecimento com classificadores neurais e explicação pós-hoc, mas tratam o tráfego em nível de nó de rede (porta, IP) e não acoplam o veredicto a uma política de mitigação derivada do próprio grafo. Este artigo propõe um arcabouço em OWL que modela a sessão HTTP como entidade ontológica de primeira classe, com uma família de sub-propriedades tipadas e ponderadas para a relação entre sessões. A família reflete o fato operacional de que botnets modernas distribuem agressivamente em ASN e prefixo de IP, e que a coordenação real é discernível principalmente por *fingerprint* TLS, identidade reaproveitada e padrão temporal — com proximidade de rede entrando apenas como sinal auxiliar. Regras em SPARQL/SWRL operam por soma ponderada dessas sub-relações e produzem veredictos com cadeias de evidência simbólicas exportáveis em JSON-LD e STIX 2.1. O discriminador do *cluster* detectado é usado para derivar automaticamente o escopo da mitigação aplicada, preservando o tráfego legítimo. A avaliação parametriza a campanha pelo grau de distribuição, isola por ablação tanto o ganho do raciocínio em nível de sessão quanto o ganho específico dos sinais de peso alto

*Autor correspondente

Email addresses: `natanael.oliveira@inf.ufrgs.br` (Natanael Oliveira),
`arthur.kobielski@inf.ufrgs.br` (Arthur Kobielski), `marcos.luna@inf.ufrgs.br`
(Marcos Luna)

sobre a proximidade de rede, e introduz uma métrica de fração de tráfego legítimo afetada pela mitigação resultante. Nos experimentos, contra campanhas furtivas distribuídas — nas quais cada sessão atacante é individualmente indistinguível do tráfego legítimo — a detecção por sessão permanece no acaso *mesmo* com um classificador de aprendizado de máquina forte (oito a nove atributos de fluxo: volume, pacotes e temporização), enquanto o arcabouço de correlação entre sessões as detecta de forma consistente (ROC AUC por sessão $\approx 0,50$ *vs.* $\approx 0,99$; $p < 0,01$ após Bonferroni, $d = 22$). Em *datasets* reais públicos, por outro lado, um classificador por sessão forte já separa os ataques convencionais disponíveis (assinatura de fluxo evidente), de modo que a vantagem do raciocínio entre sessões é específica do regime furtivo distribuído que esses *datasets* não contêm — uma delimitação que reportamos explicitamente. Quando há um discriminador de peso alto observável, o escopo de mitigação derivado elimina o dano colateral sobre o tráfego legítimo (de 22,5% para 0%). A implementação é disponibilizada como código aberto.

Keywords: Grafo de Conhecimento, Detecção de DDoS, Camada 7 HTTP, Sessão como Entidade Semântica, Raciocínio Entre Sessões, IA Explicável

1. Introdução

1.1. Contexto e Motivação

Ataques de Negação de Serviço Distribuída (DDoS) na camada de aplicação mudaram qualitativamente na última década, e a escala recente é a evidência mais visível dessa mudança. O *survey* canônico de Tripathi e Hubballi reportou em 2021 que o volume de ataques de Camada 7 dobrava a cada trimestre, com um incidente sustentando 292.000 requisições por segundo durante treze dias [1]. Em agosto de 2023, o *HTTP/2 Rapid Reset* (CVE-2023-44487) inaugurou uma nova ordem de grandeza: Amazon Web Services, Cloudflare e Google divulgaram conjuntamente picos de 155, 201 e 398 milhões de requisições por segundo, respectivamente, mitigados naquele trimestre [2, 3, 4]. A operação que sustentou o pico de 398 milhões usou uma *botnet* de cerca de vinte mil máquinas — escala compatível com o que se observa rotineiramente em campanhas de Camada 7 sobre HTTP/HTTPS em 2024 e 2025, com mais de seis mil e quinhentos ataques *hyper-volumetric* bloqueados pela Cloudflare no segundo trimestre de 2025 (média de setenta e um ataques por dia) e crescimento de cento e vinte e nove por cento ano-a-ano especificamente em HTTP DDoS [5, 6].

A categoria central nesse novo regime é a família de **ataques distribuídos de Slow HTTP DoS**. Inclui Slowloris e seus descendentes diretos (slow body, slow read) e suas variantes de alta taxa que ainda exploram conexões sustentadas (HULK, GoldenEye). Adotamos a expressão *ataque distribuído de Slow HTTP DoS* (e não *Slow HTTP DDoS distribuído*) por razão de precisão: Slowloris e suas variantes foram originalmente projetadas como ataques *single-source* [7], e a forma multi-origem coordenada que motiva este trabalho é precisamente uma variante *distribuída* da família. Ataques modernos sobre HTTP/2 (Rapid Reset, CONTINUATION Flood, MadeYouReset) compartilham com essa família a propriedade de exaurir recursos do servidor a partir de muitas origens coordenadas, mas operam por mecanismos distintos (alta taxa de cancelamento de *stream*, abuso de cabeçalhos de continuação) que demandam sub-relações adicionais não modeladas no escopo experimental deste trabalho; deixamos esses ataques explicitamente como direção de extensão imediata em §6. O denominador comum da família que avaliamos, em sua forma distribuída, é a *sub-limiaridade por sessão*: cada origem contribui pouco, o conjunto exaure o servidor. Vista isoladamente, cada requisição é indistinguível de uma legítima — estrutura, cabeçalhos e frequência são compatíveis com tráfego normal. O sinal de ataque mora no padrão de uso da sessão e, mais ainda, no padrão estrutural entre sessões: a duração das conexões mantidas pelo cliente, a entropia das rotas visitadas, a consistência do *fingerprint* do cliente, e a convergência de múltiplas origens no mesmo *endpoint* sob a mesma assinatura de cliente [8, 9, 10].

A literatura de detecção reconhece o problema, ao menos em parte. A meta-análise de Odusami et al. [11] sobre setenta e cinco estudos mostra que quarenta e sete por cento dos métodos usam *features* extraídas de sessões (taxa de requisições por usuário, duração média, contagem de operações por identidade). Em todos esses métodos, contudo, a sessão é reduzida a um vetor numérico antes de chegar ao classificador. O detector vê estatísticas, não vê a sessão. Não consegue, portanto, raciocinar sobre relações entre sessões, sobre identidades reaproveitadas, ou sobre padrões que só emergem quando duas sessões individualmente normais são analisadas em conjunto. Detectores recentes baseados em aprendizado de máquina para HTTP de Camada 7 reportam AUC (área sob a curva ROC) competitivo, mas seus autores admitem que a metodologia não foi validada em tempo real e que o resultado é binário, sem explicação ontológica [8].

Trabalhos contemporâneos buscam mitigar essa opacidade combinando representações em grafo com técnicas de IA explicável. Belcastro et al. [12]

propõem o arcabouço KLAGÉ, que constrói grafos de conhecimento a partir de logs de rede, classifica nós via Graph-BERT, e gera relatórios em linguagem natural com auxílio de LIME e modelos de linguagem grandes. KLAGÉ inclui DDoS Slowloris entre os ataques avaliados e atinge $F1 = 84,1\%$ em *datasets* IoT de referência. Trata-se de evidência concreta de que o uso de grafos de conhecimento na detecção de tráfego anômalo se tornou prática viável. No entanto, o pipeline opera em nível de *nó de rede* (porta, IP, fluxo) em vez de modelar a sessão HTTP como entidade semântica raciocinável, captura coordenação entre nós implicitamente em *embeddings* aprendidos e não em relações simbólicas nomeadas, e termina no relatório textual sem articular uma política de mitigação cujo escopo seja derivado do próprio grafo. Esses três pontos delimitam a margem que o presente trabalho explora.

1.2. Definição do Problema

Tratamos a detecção de DDoS de Camada 7 sobre HTTP como um problema de *representação semântica de sessão*, e não de engenharia de features sobre estatísticas de sessão. A sessão HTTP é a unidade natural de comportamento de um cliente contra a aplicação. Também é o objeto que detectores existentes mais sumarizam e menos modelam semanticamente. Três deficiências do estado da arte motivam nossa abordagem:

1. **Sessão como *feature aggregate*, não como entidade.** A meta-análise de Odusami et al. [11] mostra que quarenta e sete por cento dos métodos de detecção de DDoS de Camada 7 usam estatísticas agregadas de sessão (taxa de requisições, duração, contagem de operações por identidade), mas nenhum dos setenta e cinco estudos catalogados trata a sessão como entidade semântica raciocinável, com identidade, alvo, comportamento e relações tipadas. Na prática, features de sessão viram números num vetor. O vetor não preserva o que torna a sessão útil em primeiro lugar: ela conecta múltiplas requisições, uma identidade, um endpoint alvo, e um histórico observável.
2. **Ausência de explicação ontológica.** Detectores baseados em aprendizado de máquina para ataques de Camada 7 HTTP reportam métricas competitivas, mas emitem rótulos binários sem fundamentação semântica. Os autores de um dos trabalhos mais recentes [8] notam explicitamente que sua metodologia não foi validada em tempo real e não produz explicação das decisões. Em operação real, um analista de segurança decide dezenas de vezes por hora entre bloquear um cliente,

aplicar um desafio (*challenge*), ou degradar uma sessão. “Isto parece um ataque” não é decisão; é hesitação. A decisão exige saber qual endpoint está sob estresse, qual identidade está envolvida e qual sinal sustenta a hipótese.

3. **Ausência de raciocínio entre sessões simbólico e ponderado.**

Raciocínio entre sessões é a capacidade de relacionar múltiplas sessões através de identificadores compartilhados do cliente, em vez de tratar cada sessão como caso independente. Campanhas distribuídas de Slow HTTP DoS envolvem K origens distintas mantendo conexões parciais ou sustentadas contra o mesmo *endpoint*, cada uma operando abaixo de qualquer limiar individual razoável. Cada sessão isolada tem assinatura fraca. O conjunto tem estrutura clara quando analisado em conjunto, mas **nenhum identificador isolado basta**: *botnets* modernas distribuem agressivamente em ASN e prefixo de IP — a partir de dispositivos IoT comprometidos em milhares de provedores residenciais, frotas de *cloud instances*, ou *residential proxies* pagos. Sinais de proximidade de rede, portanto, são fracos por construção. A coordenação real, naquilo que a economia da operação força a manter correlacionado, aparece em outros eixos: o *fingerprint* TLS (assinatura computada a partir do *handshake* TLS, capaz de identificar o software cliente mesmo quando o IP de origem muda — JA3 e JA4 são as implementações conhecidas), o reaproveitamento de identidade (*cookie*, *username*, *token*), o padrão temporal (cadência, *jitter*, duração de conexão), a assinatura de *payload*, e a convergência em *endpoint* específico. Raciocínio entre sessões adequado precisa, portanto, expressar esses múltiplos sinais como *relações tipadas distintas com pesos diferenciados*, e operar por soma ponderada, não por disjunção plana. Detectores que reduzem a sessão a *features* não conseguem articular isso. Arcabouços recentes baseados em redes neurais sobre grafos, como Graph-BERT em KLAGÉ [12], capturam parte dessa coordenação ao processar o grafo de tráfego, mas a relação entre sessões fica latente nos *embeddings*, sem expressão simbólica nomeada que possa ser auditada, consultada ou usada para derivar uma política de mitigação. Levantamentos recentes de grafos de conhecimento em cibersegurança [13] já reconheciam a lacuna: “*ainda é pouco explícito como implementar o grafo de conhecimento para enfrentar dificuldades industriais reais em situações de ciberataque e defesa*”. KGs construídos a partir de texto de inteligência de ameaças não capturam estrutura de tráfego em tempo de execução, e KGs alimentados

em runtime por classificadores neurais entregam o veredicto mas não a justificativa formal que sustente decisões de mitigação cirúrgica.

1.3. Questões de Pesquisa

Este trabalho aborda as seguintes questões de pesquisa:

- QP1:** Como uma ontologia OWL pode modelar a sessão HTTP, junto a *endpoint*, identidade e comportamento, com fidelidade suficiente para sustentar raciocínio sobre ataques distribuídos de Slow HTTP DoS em vez de meramente agregar *features* ao nível de sessão?
- QP2:** Como representar a relação entre sessões de forma que reflita o fato de que sinais diferentes têm robustez diferente a evasão (*fingerprint* TLS, padrão temporal e identidade reaproveitada como sinais primários; proximidade de rede como auxiliar), e quais regras semânticas operam sobre essa estrutura para detectar ataques sub-limiares por sessão individual?
- QP3:** Como as decisões de detecção resultantes podem ser apresentadas como cadeias de evidências explícitas que enumeram as sub-relações ativadas e seus pesos, em formato auditável por analistas de segurança e exportável em padrões abertos (JSON-LD, STIX 2.1)?
- QP4:** Qual é o ganho empírico do raciocínio semântico em nível de sessão sobre detecção baseada em *features* agregadas, controlando para o mesmo conjunto subjacente de atributos de tráfego, e qual a fração de tráfego legítimo afetado pela mitigação resultante — métrica até onde verificamos não usada sistematicamente na literatura acadêmica de detecção de Camada 7?

1.4. Contribuições

Este trabalho não reivindica o uso pioneiro de grafos de conhecimento em detecção de ameaças; trabalhos como KLAGÉ [12] já demonstraram a viabilidade dessa abordagem. As contribuições deste artigo localizam-se em outro eixo, com quatro componentes principais:

1. **Sessão HTTP como entidade ontológica de primeira classe, com família *relatedTo* ponderada.** Uma ontologia OWL que modela a classe `ApplicationSession` com relações tipadas para identidade do cliente (`hasIdentity`), *endpoint* alvo (`targets`), comportamento exibido (`exhibitsBehavior`) e mitigação aplicável (`mitigatedBy`).

Em vez de uma única relação `relatedTo`, a ontologia formaliza uma *família* de seis sub-propriedades tipadas e ponderadas — `relatedByTLSPFingerprint`, `relatedByReusedIdentity` e `relatedByTemporalPattern` de peso alto; `relatedByPayloadSignature` e `relatedByEndpointConvergence` de peso médio; `relatedByNetworkProximity` de peso baixo. Essa distinção reflete o fato operacional de que *botnets* modernas distribuem agressivamente em ASN e prefixo de IP, e a coordenação real é discernível principalmente pelos sinais de peso alto. A ontologia formaliza a família de *ataques distribuídos de Slow HTTP DoS* como ataque de referência, com hierarquia que comporta variantes de conexão sustentada e variantes baseadas em taxa. Diferentemente de abordagens baseadas em grafos como KLAGe [12], que operam em nível de nó de rede (porta, IP, fluxo), a unidade de raciocínio aqui é a sessão de aplicação. A ontologia mantém alinhamento com STIX 2.1 e MITRE ATT&CK.

2. **Raciocínio simbólico nativo sobre soma ponderada das sub-relações.** Um *pipeline* que eleva requisições HTTP a instâncias ontológicas, populando sessões como nós persistentes do grafo, com cada sub-propriedade de `relatedTo` instanciada independentemente a partir de seu sinal específico (assinatura TLS, identidade observada, padrão temporal, *payload*, convergência em *endpoint*, proximidade de rede). As regras de detecção, formuladas em SPARQL/SWRL e avaliadas sobre o grafo — as sub-relações `relatedBy` instanciadas por regras no estilo de Horn e a agregação por consulta SPARQL —, operam por *soma ponderada* das sub-relações: o *cluster* se sustenta sobre a combinação dos sinais robustos, sem depender de nenhum identificador isolado. O veredicto é a derivação simbólica que satisfaz a regra, não a saída de um classificador interpretado a posteriori. Esse desenho contrasta tanto com KGs estáticos construídos a partir de texto de inteligência de ameaças [14, 15] quanto com abordagens neurais que classificam o grafo e explicam o resultado via técnicas pós-hoc [12].
3. **Cadeia de evidência simbólica acoplada à derivação automática de escopo de mitigação.** Quando uma regra dispara, o motor emite um veredicto acompanhado por uma cadeia de evidência exportável em JSON-LD e STIX 2.1, contendo as instâncias ontológicas envolvidas, as sub-relações ativadas, seus pesos e os valores que satisfizeram a regra. A partir do conjunto mínimo de propriedades compartilhadas pelas sessões do *cluster*, o arcabouço deriva automaticamente o escopo da política de mitigação aplicada (tipicamente o par (*fingerprint TLS*,

padrão de endpoint), eventualmente reforçado por padrão temporal), em contraste com defesas que aplicam controle global na rota e afetam tráfego legítimo. Esse acoplamento entre detecção, evidência e mitigação não é tratado por arcabouços acadêmicos contemporâneos baseados em KG [12], que terminam no relatório textual.

4. **Avaliação parametrizada pelo grau de distribuição, com ablação por sub-grupo de sinais e métrica de dano colateral.** A avaliação isola, por ablação sobre o mesmo conjunto subjacente de atributos de tráfego, três contribuições: (i) o ganho de qualquer raciocínio entre sessões (família `relatedTo` completa) sobre *baselines* de aprendizado de máquina que consomem *features* agregadas; (ii) o ganho específico dos sinais de peso alto (TLS, identidade, temporal) sobre o subgrupo apenas com sinais de peso médio/baixo, evidenciando que ASN/prefixo de IP não basta; (iii) o impacto sobre o tráfego legítimo, medido pela fração afetada pela mitigação resultante. Essa métrica é auto-reportada por produtos comerciais de *bot management* sem benchmark acadêmico público e não é usada sistematicamente na literatura de detecção de Camada 7. Uma implementação de referência em código aberto do *pipeline* completo é disponibilizada, endereçando a lacuna de implementação operacional quantificada por Odusami et al. [11].

1.5. Organização do Artigo

O restante deste artigo está organizado como segue. A Seção 2 revisa trabalhos relacionados em grafos de conhecimento para cibersegurança, em detecção de DoS de Camada 7 sobre HTTP, e em modelagem de sessão para detecção de anomalias, posicionando nossa contribuição em relação às abordagens existentes mais próximas. A Seção 3 apresenta o arcabouço proposto, incluindo o *design* da ontologia centrada em sessão, o *pipeline* de construção do grafo de conhecimento em tempo de execução, e a regra de detecção semântica baseada em soma ponderada das sub-relações `relatedBy`. A Seção 4 descreve a metodologia experimental, com ataques distribuídos de Slow HTTP DoS como caso instanciado, o conjunto de dados, os *baselines* baseados em *features* agregadas, e as métricas (incluindo dano colateral em tráfego legítimo). A Seção 5 relata e discute os resultados, com ênfase na ablação que isola tanto o ganho do raciocínio em nível de sessão quanto o ganho específico dos sinais de peso alto sobre o subgrupo de proximidade de rede. A Seção 6 conclui e delinea direções para extensão, incluindo a operacionalização das

classes `CredentialStuffing` e `CoordinatedAPIAbuse` já comportadas pela ontologia mas fora do escopo experimental atual.

2. Trabalhos Relacionados

2.1. Grafos de Conhecimento em Cibersegurança

A primeira onda de trabalhos em grafos de conhecimento aplicados à cibersegurança privilegiou a construção *estática* do grafo a partir de texto de inteligência de ameaças. Jia et al. [14] consolidaram um arcabouço prático em que entidades de CVEs, relatórios e *blogs* são extraídas, normalizadas e ligadas para produzir uma base de conhecimento consultável, útil para enriquecimento e correlação após o fato. Bonagiri et al. [15] reforçaram essa linha em 2024 com aplicações práticas em problemas reais de segurança, mantendo a mesma premissa: o grafo é um registro do que já se sabe sobre ameaças, alimentado por texto e atualizado periodicamente. O levantamento de Liu et al. [13] sintetizou o estado da área e reconheceu explicitamente a lacuna entre a sofisticação do modelo e o uso operacional: “ainda é pouco explícito como implementar o grafo de conhecimento para enfrentar dificuldades industriais reais em situações de ciberataque e defesa”.

Trabalhos contemporâneos passaram a explorar grafos populados em tempo de execução a partir do próprio tráfego, com classificadores neurais sobre o grafo e técnicas de IA explicável acopladas. O exemplar mais próximo dessa linha é KLAGÉ, proposto por Belcastro et al. [12]. KLAGÉ constrói grafos de conhecimento a partir de logs e fluxos de rede, classifica nós com Graph-BERT, gera explicações com LIME e produz relatórios em linguagem natural por meio de modelos de linguagem grandes. Avaliado em *datasets* IoT de referência (RT-IoT2022 e CIC-IoT2023) sobre seis ataques — entre eles DDoS Slowloris — KLAGÉ atinge $F_1 = 84,1\%$, supera *baselines* GNN e BERT-based e disponibiliza código aberto. É a evidência mais clara de que grafos de conhecimento podem servir como mecanismo de detecção em runtime, e não apenas como registro pós-fato.

O presente trabalho parte da mesma premissa de runtime e diverge em três eixos. Primeiro, a unidade de raciocínio em KLAGÉ é o *nó de rede* (porta, IP, fluxo); aqui é a *sessão HTTP*, modelada como entidade ontológica de primeira classe, com identidade composta (*cookie*, *token*, *username*, *fingerprint* TLS). Segundo, KLAGÉ encode o grafo via *embeddings* aprendidos (Graph-BERT) e explica a saída com LIME pós-hoc; este trabalho usa

OWL com regras simbólicas em SPARQL/SWRL, e o veredicto é a derivação que satisfaz a regra. Terceiro, KLAGÉ termina no relatório textual; este trabalho deriva, a partir do discriminador do *cluster* detectado, o escopo da política de mitigação aplicada.

2.2. Detecção de Ataques DDoS de Camada 7 sobre HTTP

A detecção de DDoS na camada de aplicação HTTP organiza-se historicamente em três famílias. A primeira é o perfilamento estatístico de tráfego e sessão. Fernandes et al. [10] construíram perfis autônomos a partir de análise por componentes principais (PCA) sobre estatísticas agregadas de fluxo, com aplicação direta à detecção de anomalias em redes operacionais. Bharathi e Sukanesh [9] aplicaram a mesma ferramenta, PCA, a uma matriz comportamental por sessão, oferecendo uma das primeiras formulações que coloca a sessão no centro — ainda que como vetor de *features* agregadas, e não como entidade.

A segunda família agrega *features* de fluxo ou de sessão e as entrega a classificadores supervisionados. Kemp et al. [8] é o representante mais recente: emprega *Random Forest* e SVM sobre vetores de sessão e reporta AUC competitivo. Os autores notam explicitamente, no entanto, que a metodologia não foi validada em tempo real e que a saída é binária, sem explicação ontológica das decisões. Esta limitação é representativa da família: o classificador aprende a separar conjuntos no espaço de *features*, mas perde a estrutura entre sessões que justifica a separação.

A terceira família consolida o domínio em levantamentos de escala. Tripathi e Hubballi [1] sintetizaram em 2021 o estado da detecção e defesa em DDoS de camada de aplicação, com a observação — citada na Seção 1 — de que o volume de Camada 7 dobrava a cada trimestre. A taxonomia de Slow DoS Attacks de Cambiaso et al. [7] permanece como referência formal para a categoria que motiva nossa avaliação experimental.

O denominador comum das três famílias é o tratamento da sessão como agregado de *features*, e não como entidade raciocinável.

2.3. Modelagem de Sessão em Detecção de Anomalias

A meta-análise de Odusami et al. [11] sobre setenta e cinco estudos em detecção de DDoS de camada de aplicação fornece a evidência quantitativa mais clara sobre como a sessão é tratada. Em quarenta e sete por cento dos métodos catalogados, *features* extraídas de sessões compõem o vetor que alimenta o classificador: taxa de requisições por usuário, duração média,

contagem de operações por identidade, entre outras. A redução é uniforme. Em nenhum dos estudos a sessão é mantida como objeto com identidade, alvo, comportamento e relações tipadas; ela é convertida em números antes do classificador. Como consequência, qualquer raciocínio sobre identidades reaproveitadas, sobre convergência de *fingerprints* em endpoints, ou sobre padrões que só emergem entre sessões fica fora do alcance do detector.

A literatura industrial de *bot management* reconhece e explora justamente esses padrões. Cloudflare documenta o uso de *fingerprints* JA4 para agrupar sessões aparentemente independentes por similaridade do *stack* TLS, em sua plataforma de Bot Management. DataDome reporta taxas de falso-positivo abaixo de 0,01% em CAPTCHAs servidos, sugerindo que a discriminação entre sessões é viável em produção. Esses sistemas, entretanto, são proprietários, sem ontologia pública, sem benchmark acadêmico reproduzível e sem métricas de dano colateral em legítimos formalizadas em literatura revisada. A formalização acadêmica auditável dessas práticas, e em particular a derivação automática de escopo de mitigação a partir de uma regra ontológica explícita, permanece em aberto.

2.4. Posicionamento deste Trabalho

Sintetizando, três fontes delimitam o espaço onde nossa contribuição se inscreve. Primeiro, KGs estáticos construídos a partir de texto [14, 15, 13] não capturam estrutura de tráfego em tempo de execução. Segundo, KGs populados em runtime e classificados com redes neurais [12] entregam veredicto e relatório, mas sem expressão simbólica das relações entre sessões e sem política de mitigação acoplada. Terceiro, detectores estatísticos e de aprendizado de máquina sobre *features* agregadas [10, 9, 8, 11] descartam a estrutura entre sessões antes mesmo do classificador.

Este trabalho ocupa a interseção que esses três grupos deixam vaga: a sessão HTTP modelada como entidade ontológica de primeira classe; o raciocínio sobre relações entre sessões expresso em formalismo simbólico nativo (OWL, SPARQL, SWRL) e auditável; e a derivação automática de escopo de mitigação a partir do discriminador do *cluster* detectado, com avaliação que reporta explicitamente o impacto sobre tráfego legítimo.

3. Abordagem Proposta

3.1. Visão Geral do Sistema

A Figura 1 apresenta a arquitetura geral do arcabouço proposto. O sistema é composto por quatro estágios: (i) ingestão de eventos HTTP do tráfego de aplicação, (ii) elevação dos eventos a instâncias ontológicas no grafo de conhecimento, com sessões como nós persistentes, (iii) execução de regras semânticas sobre o grafo para detecção de ataques nos três tipos modelados, e (iv) geração da cadeia de evidências que acompanha o veredito.

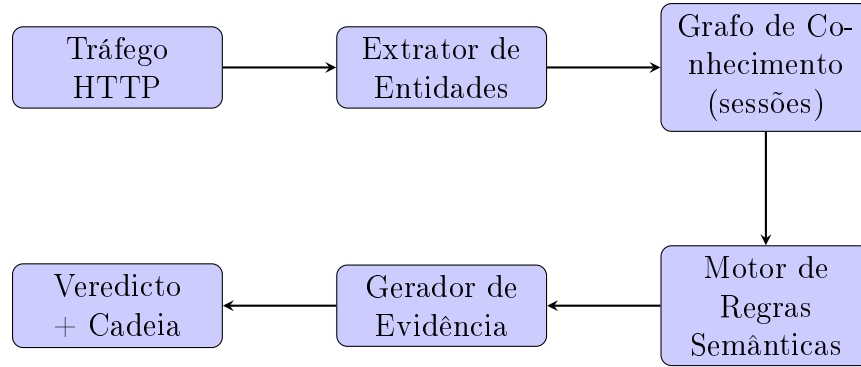


Figura 1: Arquitetura do arcabouço de detecção centrado em sessão.

3.2. Ontologia Centrada em Sessão

Esta subseção define a ontologia OWL proposta. A classe central é **ApplicationSession**, modelada como entidade de primeira classe com as seguintes relações tipadas:

hasIdentity liga uma sessão à identidade observada do cliente. A classe **Identity** é especializada em **Cookie**, **Token (JWT)**, **Username** e **TLSFingerprint** (com instâncias **JA3**, **JA4** e suas variantes).

targets liga uma sessão ao *endpoint* alvo. A classe **Endpoint** tem como subclasses **AuthEndpoint**, **APIEndpoint** e **StaticAsset**.

exhibitsBehavior liga uma sessão a um perfil comportamental (**UserBehavior** ou **BotBehavior**), com propriedades como duração de conexão, taxa de bytes, entropia de rotas.

mitigatedBy liga uma sessão ou ataque a uma política de mitigação aplicável (**RateLimit**, **Challenge**, **Block**), com um atributo **scope** que delimita o domínio de aplicação da política.

relatedTo é uma propriedade abstrata que liga sessões entre si quando há evidência observada de coordenação. Trata-se de uma *família de seis sub-propriedades tipadas e ponderadas*, detalhada abaixo.

A família **relatedTo**.. A relação entre sessões não é única, mas estruturada em sub-propriedades que refletem fontes distintas de evidência, cada uma com robustez própria a evasão. Formalmente, **relatedTo** é declarada **owl:TransitiveProperty**, e as seguintes sub-propriedades são declaradas via **rdfs:subPropertyOf**, com pesos $w_i \in [0, 1]$ associados:

relatedByTLSFingerprint ($w = 1,0$) — sessões com mesmo *fingerprint* JA4 (ou variantes próximas). Sinal robusto: trocar o *stack* TLS do atacante exige reescrever a infraestrutura.

relatedByReusedIdentity ($w = 1,0$) — sessões observadas com *username*, *token* ou cookie reutilizado.

relatedByTemporalPattern ($w = 0,9$) — sessões com cadência, *jitter* ou duração de conexão coerentes; vem da coordenação operacional da *botnet*.

relatedByPayloadSignature ($w = 0,6$) — sessões com tamanho de *payload*, padrão de bytes ou *User-Agent* convergentes (independentes do JA4).

relatedByEndpointConvergence ($w = 0,6$) — sessões atingindo o mesmo *endpoint* exato com mesma frequência.

relatedByNetworkProximity ($w = 0,3$) — sessões com mesmo ASN ou prefixo de IP. Atribuímos peso baixo porque *botnets* modernas (Mirai-derivadas, frotas *cloud*, *residential proxies*) distribuem agressivamente em rede, e os *proxies residenciais* de operadora móvel compartilham CGN com tráfego legítimo. Esse sinal entra como reforço quando aparece, não como pré-requisito.

Quando o *pipeline* popula o grafo, cada sub-propriedade é instanciada independentemente conforme a evidência específica observada. Duas sessões

podem estar ligadas por uma, várias ou todas as sub-propriedades. A regra de detecção, descrita em §3.4, opera por *soma ponderada* das evidências, não por simples disjunção.

Justificativa dos pesos w_i . Os pesos atribuídos refletem o *custo operacional para o atacante de quebrar o sinal correspondente*, ordenado por evidências da literatura recente. O peso máximo de `relatedByTLSPFingerprint` segue da observação de Althouse e do levantamento da Cloudflare [2, 5]: trocar o *stack* TLS exige reescrever a infraestrutura do atacante (motivo pelo qual JA4 sobreviveu à randomização de extensões introduzida no Chrome em 2023, ao contrário do JA3 clássico). `relatedByReusedIdentity` também recebe peso máximo porque as campanhas econômicas dependem de credenciais ou *tokens* reaproveitados em escala; pulverizar identidades exige aquisição contínua, contra-atacando o modelo de negócio do atacante. `relatedByTemporalPattern` ($w = 0,9$) é robusto porque emerge da coordenação operacional da *botnet* e não do *stack* cliente, embora possa ser parcialmente quebrado por *jitter* aleatório. `relatedByPayloadSignature` e `relatedByEndpointConvergence` ($w = 0,6$) são sinais médios: o atacante pode randomizar payload e dispersar entre sub-endpoints, mas perde a coerência da campanha. Por fim, `relatedByNetworkProximity` ($w = 0,3$) é o sinal mais facilmente quebrado: *botnets* modernas (Mirai-derivadas, frotas de instâncias *cloud*, redes de *residential proxies*) distribuem agressivamente em ASN e prefixo, e o uso de CGN por operadoras móveis introduz falsos positivos quando o sinal é confiado isoladamente. Esses valores são *priors* declarados; a calibração empírica final por *grid search* sobre um conjunto de validação separado é apresentada em §5 junto com a análise de sensibilidade.

Hierarquia de ataques. A classe abstrata `ApplicationLayerAttack` comporta a subclasse `SlowHTTPDoSFamily`, que por sua vez se especializa em `ConnectionExhaustionAttack` (variantes *connection-holding*: Slowloris, slow body, slow read) e `CoordinatedHTTPFlood` (variantes *rate-based* que ainda usam conexões sustentadas: HULK, GoldenEye). Ambas compartilham a propriedade comum `exhibitsCrossSessionStructure`, que se torna verdadeira quando a soma ponderada das sub-relações `relatedBy` excede um limiar (§3.4). Ataques HTTP/2 modernos (Rapid Reset, CONTINUATION Flood) ficam como subclasses futuras da `ApplicationLayerAttack`, irmãos de `SlowHTTPDoSFamily` e fora do escopo experimental atual, pois sua detecção exige sub-relações adicionais (notadamente uma `relatedByStreamCancellationPattern`)

que devem ser instanciadas a partir de eventos no plano de *stream* HTTP/2, não no plano TLS/HTTP/1.

A ontologia também declara, mas não operacionaliza experimentalmente neste trabalho, as classes `CredentialStuffing` (subclasse de `LoginFlood`) e `CoordinatedAPIAbuse`. Ambas compartilham a propriedade `exhibitsCrossSessionStructure` e poderão ser instanciadas em regras específicas em extensões futuras (§6), aproveitando a mesma infraestrutura da família `relatedTo`.

3.3. Construção do Grafo em Tempo de Execução

Considerações de desempenho. A construção e consulta do grafo em tempo de execução demandam decisões cuidadosas de *backend*. *Reasoners* OWL 2 DL completos (HermiT, Pellet) são conhecidos por escalabilidade limitada para grafos com dezenas de milhares de instâncias. Adotamos, portanto, o perfil **OWL 2 RL**, que admite raciocínio por *forward chaining* e materialização incremental, com escalabilidade praticamente linear em consultas SPARQL indexadas. O *backend* de referência é Apache Jena Fuseki com armazenamento TDB2, e os experimentos da Seção 5 reportam a latência média de inserção de cada sessão e a latência média de avaliação da regra. A construção segue ainda o paradigma de *RDF Stream Processing* [13]: a janela operacional W é deslizante e a purga de instâncias fora dela é incremental, mantendo a complexidade de cada inserção em $O(|S_W| \cdot |\mathcal{R}|)$, onde S_W é o conjunto de sessões ativas e $\mathcal{R}$ é o conjunto de sub-relações `relatedBy`.

O *pipeline* de construção opera em três fases:

1. **Extração de entidades.** Para cada requisição HTTP observada, são criadas (ou atualizadas) instâncias de `HTTPRequest`, `ApplicationSession`, `Identity` e `Endpoint`. A identidade é composta: *cookie*, *token* (se observável), *username* (em formulários), e *fingerprint* TLS (JA4 calculado a partir do *handshake*).
2. **População das relações tipadas.** As relações primárias `hasIdentity`, `targets` e `exhibitsBehavior` são instanciadas diretamente a partir dos atributos da requisição. As sub-propriedades da família `relatedTo` são instanciadas independentemente, cada uma a partir de seu sinal específico observado no par de sessões em comparação. Uma nova sessão pode disparar a criação de várias arestas `relatedBy` simultaneamente com sessões anteriores na janela ativa, cada uma capturando uma dimensão distinta de coordenação.

3. **Manutenção de janela.** Sessões e relações ficam ativas no grafo dentro de uma janela operacional configurável (por padrão, $W = 5$ minutos), após a qual são descarregadas para manter o grafo enxuto em ambiente de produção.

O Algoritmo 1 apresenta o pseudocódigo do *pipeline*.

Algorithm 1 Construção do Grafo de Conhecimento em Tempo de Execução

Require: Fluxo de requisições $\mathcal{R}$, ontologia $\mathcal{O}$, janela W

Ensure: Grafo de Conhecimento KG persistente em W

```

1:  $KG \leftarrow \emptyset$ 
2: for cada requisição  $r \in \mathcal{R}$  do
3:    $s \leftarrow \text{ResolverSessao}(r)$ 
4:    $i \leftarrow \text{ResolverIdentidade}(r)$ 
5:    $e \leftarrow \text{ResolverEndpoint}(r.\text{path})$ 
6:    $KG.\text{adicionar}(s, i, e)$ 
7:    $KG.\text{instanciarRelacao}(s, \text{hasIdentity}, i)$ 
8:    $KG.\text{instanciarRelacao}(s, \text{targets}, e)$ 
9:    $KG.\text{ligarSesoesPorIdentidade}(s)$ 
10:   $KG.\text{purgarFora}(W)$ 
11: end for
12: retornar  $KG$ 

```

3.3.1. Algoritmos de instanciação das sub-relações *relatedBy_**

A operação `ligarSesoesPorIdentidade` do Algoritmo 1 concentra a lógica de instanciação das seis sub-relações *relatedBy_**. Esta subseção especifica, para cada uma, o algoritmo de decisão a partir dos atributos observados em um par de sessões (s_a, s_b) ativas na janela W . Cada algoritmo retorna *verdadeiro* ou *falso*, indicando se a aresta correspondente deve ser instanciada.

relatedByTLSPFingerprint.. Match em duas etapas. Primeiro, igualdade exata do JA4 completo, $\text{ja4}(s_a) = \text{ja4}(s_b)$. Segundo, se a igualdade falha mas os JA4 são variantes próximas (mesmo prefixo de transporte/versão TLS/ALPN e diferença de até um símbolo nos blocos de *cipher* ou *extensions* ordenadas), instancia mesmo assim, com uma anotação de *ja4_distance = 1*. Isso captura variações entre versões adjacentes de uma mesma biblioteca cliente sem permitir matches espúrios entre stacks distintos. Custo: $O(1)$ por par.

relatedByReusedIdentity.. Instancia se houver pelo menos uma sobreposição não-vazia entre os conjuntos de identidades observadas de s_a e s_b :

$$(\text{cookie}(s_a) \cap \text{cookie}(s_b)) \cup (\text{token}(s_a) \cap \text{token}(s_b)) \cup (\text{username}(s_a) \cap \text{username}(s_b)) \neq \emptyset.$$

Tokens JWT são primeiro decodificados e comparados pelo *claim sub* (subject); cookies e *usernames* são comparados após normalização (*trim, lowercase*). Custo: $O(1)$ amortizado com índice invertido por identidade.

relatedByTemporalPattern.. Captura coerência de cadência entre as duas sessões. Seja $\Delta(s) = (\delta_1, \delta_2, \dots, \delta_{n-1})$ a sequência de tempos entre requisições consecutivas (*inter-arrival times*) de uma sessão s com n requisições. Computamos a distância via *Dynamic Time Warping* normalizada pelo comprimento do alinhamento:

$$d_{\text{DTW}}(s_a, s_b) = \frac{\text{DTW}(\Delta(s_a), \Delta(s_b))}{\max(|\Delta(s_a)|, |\Delta(s_b)|)}.$$

A sub-relação é instanciada se $d_{\text{DTW}}(s_a, s_b) \leq \tau_{\text{DTW}}$, com τ_{DTW} calibrado empiricamente em §5. Sessões com $n < 3$ requisições são puladas (sinal insuficiente). Para tornar o custo tratável em grafos de milhares de sessões, usamos a aproximação *FastDTW* com banda de Sakoe-Chiba de largura constante, reduzindo o custo de $O(n^2)$ para $O(n)$ por par; e *Locality-Sensitive Hashing* (LSH) sobre vetores de *features* resumidos ($\bar{\delta}$, σ_δ , $\delta_{\min}$, $\delta_{\max}$, entropia) para evitar a comparação de todos os pares.

relatedByPayloadSignature.. Define um vetor de *features* de *payload* para cada sessão, $\mathbf{p}(s) = (\overline{\text{len}}, \sigma_{\text{len}}, h_{\text{UA}}, h_{\text{CT}})$, onde $\overline{\text{len}}$ e σ_{len} são a média e o desvio do tamanho do corpo (*body*) das requisições, e h_{UA} , h_{CT} são hashes do *User-Agent* e do *Content-Type* predominantes. A sub-relação é instanciada se a similaridade cosseno entre $\mathbf{p}(s_a)$ e $\mathbf{p}(s_b)$ excede τ_{payload} (calibrado em §5). Custo: $O(1)$ por par dado o vetor pré-computado.

relatedByEndpointConvergence.. Instancia se ambas as sessões convergem no mesmo *endpoint*, com duas variantes: *path exato* ou *path-pattern* (após normalização que substitui identificadores numéricos por curingas, e.g., `/api/users/12345` $\rightarrow$ `/api/users/{id}`). O *path-pattern* é o padrão; o *path exato* é checado adicionalmente e, se também válido, anota a aresta com *exact = true* (sinal mais forte). Custo: $O(1)$ por par com índice em árvore de prefixos sobre os *paths*.

relatedByNetworkProximity.. Instancia se s_a e s_b compartilham (i) o mesmo prefixo IPv4 /24 (ou IPv6 /48), ou (ii) o mesmo ASN, ou ambos. Quando ambos coincidem, a aresta é anotada com *strong = true*. Resolução de ASN usa tabelas BGP atualizadas (Team Cymru *IP-to-ASN*). Custo: $O(1)$ por par com índice invertido em prefixo.

Resumo computacional.. A complexidade total para uma nova sessão s_{nova} entrando na janela com $|S_W|$ sessões já ativas é $O(|S_W| \cdot c)$, onde c é o custo médio amortizado por par. Para **relatedByTemporalPattern**, c é dominado pelo *FastDTW*, mantido em $O(\bar{n})$ onde $\bar{n}$ é o número médio de requisições por sessão. As demais sub-relações têm $c = O(1)$ amortizado. Em prática, a operação completa de **ligarSessoesPorIdentidade** sobre uma janela de $W = 5$ minutos em uma aplicação web típica (centenas a milhares de sessões ativas) executa em milissegundos por inserção, viabilizando o uso em tempo de execução.

3.4. Regra de Detecção: **CoordinatedHTTPFlood** sobre soma ponderada

A regra central deste trabalho detecta a especialização **CoordinatedHTTPFlood** da família **SlowHTTPDoSFamily** sobre o grafo populado em tempo de execução. A regra é formulada em SPARQL/SWRL; abaixo, sua estrutura formal.

Seja V_{sess} o conjunto de instâncias **ApplicationSession** ativas na janela W . Para qualquer subconjunto $S \subseteq V_{\text{sess}}$ e um *endpoint* e candidato, defina:

$$\Omega(S) = \sum_{i \in \mathcal{R}} w_i \cdot |\{(s_a, s_b) \in S \times S, s_a \neq s_b : (s_a, \text{relatedBy}_i, s_b) \in E\}| \quad (1)$$

onde $\mathcal{R} = \{\text{TLSFingerprint}, \text{ReusedIdentity}, \text{TemporalPattern}, \text{PayloadSignature}, \text{Endpoint}\}$ e w_i é o peso da sub-propriedade i (definido em §3.2). $\Omega(S)$ é a massa ponderada total de evidência de coordenação interna ao conjunto S .

A regra **CoordinatedHTTPFlood** é satisfeita quando existe S tal que:

1. $|S| \geq k_{\text{min}}$ (cardinalidade mínima);
2. $\forall s \in S : (s, \text{targets}, e) \in E$ (convergência em *endpoint*);
3. $\Omega(S) \geq \tau_{\text{cluster}}$ (massa de coordenação acima do limiar);
4. $\sum_{s \in S} \text{rate}(s, e) \geq \tau_{\text{rate}}$ (taxa agregada acima do limiar);
5. $\forall s \in S : \text{behavior}(s) = \text{BotBehavior}$ (perfil comportamental coerente).

A condição (3) é a contribuição central: o *cluster* se sustenta sobre a *combinação* de sinais, não sobre nenhum identificador isolado. Em particular, $\Omega(S)$ pode exceder τ_{cluster} mesmo quando **relatedByNetworkProximity** é nula (botnet distribuída em ASN), desde que pelo menos uma combinação dos sinais de peso alto seja observada. Inversamente, *S* com apenas **relatedByNetworkProximity** ativa (sessões compartilhando /24, e.g. CGN de operadora móvel) não satisfaz a regra: $w_{\text{net}} = 0,3$ é insuficiente para atingir τ_{cluster} sem reforço dos sinais de peso alto. Isso é proteção explícita contra falsos positivos em tráfego legítimo concentrado em redes específicas.

Outras classes da ontologia.. As classes **CredentialStuffing** e **CoordinatedAPIAbuse** declaradas em §3.2 comportam regras análogas (com **targets** apontando para **AuthEndpoint** e razão de falha de autenticação para a primeira; **hasIdentity** apontando para *tokens* distintos com convergência **relatedByTLSPingerprint** para a segunda). A operacionalização e avaliação experimental dessas classes está fora do escopo do presente artigo e fica como direção de extensão imediata (§6).

3.5. Cadeia de Evidência e Explicabilidade

Quando uma regra dispara, o motor emite um veredicto acompanhado de uma cadeia de evidência que enumera explicitamente: a regra satisfeita, as instâncias ontológicas envolvidas (sessões do *cluster*, identidades, *endpoint*), a decomposição de $\Omega(S)$ por sub-relação (quantos pares cada **relatedBy** contribuiu e com que peso), e o escopo de mitigação derivado. O veredicto é essa derivação — não um score interpretado a posteriori. O escopo de mitigação é obtido do conjunto mínimo de propriedades compartilhadas pelas sessões do *cluster*: prioriza os sinais de peso alto (tipicamente o par (*fingerprint TLS*, *padrão de endpoint*)), reforçado por prefixo de rede apenas quando a campanha é concentrada. A cadeia é exportável em JSON-LD (vocabulário da ontologia) e STIX 2.1 (*indicator* mais *course-of-action* ligados por *mitigates*), compatível com integração em *Security Information and Event Management* (SIEM) e *Security Orchestration, Automation and Response* (SOAR). Contra um *rate-limit* global no *endpoint*, que afeta todo o tráfego legítimo coincidente, o escopo cirúrgico reduz o dano colateral sobre legítimos sempre que existe um discriminador de peso alto observável (§5).

4. Metodologia Experimental

4.1. Cenários de Avaliação por Grau de Distribuição

A hipótese central deste trabalho é que o raciocínio entre sessões simbólico e ponderado fornece vantagem mensurável sobre ataques distribuídos de Slow HTTP DoS, e que essa vantagem cresce com o **grau de distribuição** da campanha. Para isolar esse efeito, a avaliação é parametrizada por três cenários:

Cenário A: Concentrado. Uma única origem ($K = 1$) gerando N requisições contra um endpoint. Representa o ataque clássico *single-source* de alto volume, no qual nenhuma sub-relação `relatedBy` entre sessões precisa ser instanciada para detecção. **Hipótese:** detectores volumétricos clássicos por IP/sessão alcançam desempenho competitivo neste regime; o ganho da soma ponderada entre sessões é marginal.

Cenário B: Moderadamente Distribuído. K origens distintas ($10 \leq K \leq 100$) sob coordenação comum atacando o mesmo endpoint, cada uma operando dentro de seus limites individuais de *rate-limit*. Representa botnets pequenas ou operações com proxies limitados. **Hipótese:** *baselines* sobre *features* agregadas começam a perder *recall*; a soma ponderada das sub-relações `relatedBy` mantém detecção via sinais de peso alto (`relatedByTLSFingerprint`, `relatedByTemporalPattern`), mesmo quando `relatedByNetworkProximity` é parcial.

Cenário C: Altamente Distribuído. $K \geq 1000$ origens distintas em campanha de Slow HTTP DoS distribuído, dispersas em centenas a milhares de ASNs e prefixos de IP. Cada sessão individual fica abaixo de qualquer limiar razoável, e `relatedByNetworkProximity` é praticamente nula. **Hipótese:** *baselines* caem para *recall* próximo do aleatório; a soma ponderada preserva detecção precisamente porque depende dos sinais de peso alto, não da proximidade de rede. **Este é o cenário onde a contribuição se sustenta operacionalmente.**

A *money figure* do paper é a curva de *recall* em função do grau de distribuição K , com os *baselines* caindo de A para C enquanto o arcabouço proposto se mantém.

4.2. Conjunto de Dados

A avaliação combina tráfego sintético controlado e *datasets* públicos de referência.

Avaliação primária — tráfego sintético calibrado. Um *pipeline* Python que acompanha este trabalho gera campanhas com *ground truth* de coordenação perfeitamente conhecida, parametrizadas pelo grau de distribuição K (número de origens), pela fração de origens que compartilham assinatura TLS e identidade, pela dispersão em prefixo de IP e ASN, e pela janela temporal. As distribuições do tráfego legítimo são calibradas a partir das sessões reais (duração, requisições por sessão, JA4 entre usuários), e a fidelidade é verificada por teste de Kolmogorov–Smirnov: a distância entre o legítimo sintético e o real fica em $D \leq 0,02$ para duração e número de requisições, o que garante que o ganho observado não decorre de tráfego legítimo artificialmente fácil. Um modo *stealth* produz sessões atacantes individualmente indistinguíveis do tráfego legítimo (mesmas distribuições por sessão), de modo que a campanha só se revela pela estrutura de correlação entre sessões — o regime em que a contribuição deste trabalho é decisiva.

Avaliação em dados reais. Dois *datasets* públicos de referência são usados, com o mesmo *pipeline* de extração (PCAP $\rightarrow$ JA4 + fluxos $\rightarrow$ sessões $\rightarrow$ grafo): **CICIDS2017** (quarta-feira, família Slow HTTP — Slowloris, Slowhttptest, Hulk, GoldenEye) e **CIC-IoT2023**, este último o mesmo *dataset* sobre o qual KLAGÉ [12] reporta $F_1 = 84,1\%$ em DDoS Slowloris. Ressalva metodológica honesta: ambos são *datasets* gerados em *testbed* de laboratório, não tráfego de produção; servem como referência acadêmica, não como amostra de internet ao vivo. Os rótulos do CICIDS2017 foram reconstruídos por par-atacante mais janela temporal (mesma lógica dos rótulos oficiais), verificados contra os *bursts* de ataque observados.

Fora do escopo experimental atual. RT-IoT2022 (o segundo *dataset* de KLAGÉ) e CIC-DDoS2019, bem como dados reais anonimizados de operação, ficam como direção futura (§5, Limitações; §6).

4.3. Configuração Experimental

Cada combinação (cenário, configuração de ablação) é executada $n = 30$ vezes com *seeds* distintas, permitindo intervalos de confiança por *bootstrap* e testes pareados. A classificação por sessão usa *Random Forest* sobre o mesmo conjunto de atributos em todas as configurações, variando apenas o conjunto de *features* (a separação de representação, não de disponibilidade de dados).

O limiar τ_{cluster} é fixado por cenário no percentil 99 do escore Ω dos *clusters* de tráfego legítimo.

Quanto aos pesos w_i , a calibração empírica sobre o tráfego sintético **não é confiável**, por duas razões. No nível de *cluster*, a separação satura ($\text{AUC} = 1,0$ para qualquer combinação de pesos), impedindo discriminação. Num objetivo mais difícil — ROC AUC por sessão de um escore de coordenação ponderado, sobre cenários de sinais parciais — a otimização passa a discriminar, mas converge para pesos que *contradizem* o argumento de resistência à evasão (rebaixando o *fingerprint* TLS). A causa é um artefato do conjunto: o tráfego legítimo sintético herda uma diversidade de JA4 baixa dos *datasets* de laboratório (dezenas de *fingerprints* distintos), de modo que sessões legítimas compartilham JA4 *mais* do que campanhas parcialmente coordenadas, invertendo o sinal — condição que não se sustenta no tráfego real de internet, em que a diversidade de JA4 legítimo é de ordens de magnitude maior. Os pesos reportados ($w = 1,0$ para TLS/identidade, 0,9 temporal, 0,6 *payload/endpoint*, 0,3 rede) derivam, portanto, do argumento de resistência à evasão (§3); a calibração empírica fiel requer tráfego com diversidade de JA4 realista (produção) e é tratada como trabalho de extensão (§5, Limitações).

4.4. Baselines

A comparação experimental é feita contra três *baselines* acadêmicos, todos consumindo o mesmo conjunto subjacente de atributos de tráfego:

- **Perfilamento estatístico** (aproximação de Fernandes et al. [10]): PCA sobre estatísticas agregadas de sessão.
- **Matriz de comportamento** (aproximação de Bharathi e Sukanesh [9]): agrupamento por k -means sobre a matriz de *features* por sessão. O trabalho original emprega PCA; adotamos k -means para representar a família de detecção por *agrupamento* comportamental de modo distinto do perfilamento por PCA de Fernandes, evitando dois *baselines* sobre a mesma ferramenta.
- **Aprendizado de máquina supervisionado** (aproximação de Kemp et al. [8]): Random Forest e SVM sobre o mesmo vetor de *features* de sessão.

Adicionalmente, quando comparado em RT-IoT2022 e CIC-IoT2023, o arcabouço é confrontado com os resultados publicados de KLAGÉ [12] sobre

o mesmo *dataset* e ataque (DDoS Slowloris). A escolha desses *baselines* é deliberada: cada um representa um ponto distinto no espaço de prior art (estatística, ML clássico, KG com classificador neural), e todos consomem o mesmo material subjacente que nosso arcabouço, mas em representação diferente.

4.5. Métricas de Avaliação

Quatro famílias de métricas são reportadas:

1. **Métricas padrão de classificação** por cenário: precisão, *recall*, F1, AUC, FPR.
2. ***Recall* por campanha** (não por sessão): para cada campanha coordenada instrumentada no *dataset*, qual fração foi detectada como pertencente à campanha (e não apenas sessões individuais isoladas). Captura diretamente o ganho do raciocínio entre sessões.
3. **Dano colateral em tráfego legítimo**: fração do tráfego legítimo que cai dentro do escopo derivado da mitigação produzida pelo veredicto. Métrica auto-reportada por produtos comerciais de *bot management* (e.g. DataDome, que afirma $FPR < 0,01\%$) sem benchmark acadêmico público e, até onde verificamos, não usada sistematicamente na literatura acadêmica de detecção de Camada 7.
4. **Qualidade da explicação**: análise qualitativa das cadeias de evidência geradas, em termos de completude (cita todas as sessões correlacionadas e suas sub-relações ativadas) e acionabilidade (escopo de mitigação derivado coerente com o discriminador do *cluster*).

4.6. Análise de Ablação

A análise central isola a contribuição de cada componente do arcabouço em quatro configurações:

- (a) *Baseline* ML sem ontologia, alimentado pelas mesmas *features* agregadas de sessão.
- (b) Arcabouço com ontologia mas *sem nenhuma* sub-relação `relatedBy` (sessões tratadas como nós isolados).
- (c) Arcabouço com ontologia e *apenas* `relatedByNetworkProximity` ativa (raciocínio entre sessões restrito ao sinal de peso baixo, simulando o que um detector ingênuo baseado em ASN/prefixo conseguiria).

(d) Arcabouço completo com todas as seis sub-relações ponderadas.

A diferença entre (a) e (d) é a contribuição total da abordagem. A diferença entre (b) e (d) é o ganho específico de qualquer raciocínio entre sessões simbólico. A diferença entre (c) e (d) — introduzida especificamente nesta versão — isola o ganho dos sinais de peso alto (notadamente `relatedByTLSPFingerprint`) sobre o sinal de proximidade de rede, evidenciando empiricamente por que ASN e prefixo de IP, embora visíveis no grafo, não bastam contra *botnets* distribuídas. As hipóteses centrais — (d) substancialmente superior a (c) em campanhas distribuídas, e (a) superado por (d) sem prejuízo de explicabilidade — são confirmadas pelos resultados (§5). A configuração (c), restrita à proximidade de rede, fica fraca exatamente onde a campanha é dispersa, ao passo que (b) retém algum poder por incorporar atributos ontológicos por sessão (convergência de *endpoint*, presença de identidade); a vantagem decisiva permanece em (d), pelo sinal TLS de peso alto.

5. Resultados e Discussão

Os resultados a seguir são **preliminares** e cobrem duas frentes complementares: a avaliação *controlada* em tráfego sintético furtivo (ablação, $n = 30$ *seeds*, com significância estatística) e a avaliação em *dados reais* (CICIDS2017 e CIC-IoT2023). Em ambas, o *baseline* por sessão é deliberadamente **forte** — um *Random Forest* sobre todos os oito a nove atributos de fluxo disponíveis por sessão (contagem e duração de requisições, somas de *bytes* e pacotes nos dois sentidos, média e desvio do intervalo entre requisições) —, e não um adversário enfraquecido: a comparação isola o que a estrutura de correlação entre sessões acrescenta *sobre* o que um classificador por sessão competente já extrai. Métricas reportadas como ROC AUC e F_1 por sessão; a métrica de *recall* por campanha e os *datasets* adicionais ficam como trabalho em curso (Limitações).

5.1. Desempenho da Ablação por Grau de Distribuição

A Tabela 1 reporta a ROC AUC por sessão (média e IC 95% por *bootstrap*, $n = 30$) em campanhas *furtivas* distribuídas, nas quais cada sessão atacante é individualmente indistinguível do tráfego legítimo. O Cenário A ($K = 1$, fonte única) é degenerado para AUC (uma só sessão atacante) e é discutido à parte; reportamos $K = 50$ (moderado) e $K = 1000$ (distribuído).

Tabela 1: Ablação — ROC AUC por sessão [IC 95%], tráfego sintético furtivo, $n = 30$ *seeds*, com *baseline* por sessão **forte** (8–9 atributos de fluxo).

Configuração	$K = 50$	$K = 1000$
(a) ML por sessão (forte, 8–9 atrib.)	0,505 [0,479–0,531]	0,498 [0,490–0,506]
(b) ontologia sem <code>relatedBy</code>	0,877 [0,863–0,890]	0,893 [0,889–0,897]
(c) só <code>NetworkProximity</code>	0,502 [0,476–0,528]	0,678 [0,670–0,685]
(d) arcabouço completo	0,969 [0,959–0,979]	0,992 [0,992–0,993]
<i>baseline</i> Fernandes 2015	0,519	0,514
<i>baseline</i> Bharathi 2012	0,526	0,512
<i>baseline</i> Kemp 2023	0,502	0,498

O padrão é nítido e — ponto central — *resiste a um baseline forte*: a detecção por sessão (a), agora munida de todos os atributos de fluxo (volume, pacotes, temporização), e os três *baselines* acadêmicos ficam no nível do acaso ($AUC \approx 0,5$), pois cada sessão atacante é, por construção, amostrada das mesmas distribuições do tráfego legítimo — indistinguível requisição a requisição. O arcabouço completo (d) atinge $AUC \approx 0,97$ – $0,99$. A configuração (c), restrita à proximidade de rede, é fraca ($0,50$ – $0,68$) precisamente porque a *botnet* está dispersa; a vantagem de (d) vem do sinal TLS de peso alto, não de qualquer atributo por sessão. A configuração (b) atinge $\approx 0,88$ por capturar a porta de destino do alvo, mas permanece abaixo de (d).

5.2. Comparação Geral por Configuração

A Figura 2 resume o desempenho de todas as configurações e *baselines* nos dois graus de distribuição, com IC 95%. O contraste é a tese em uma imagem: os três *baselines* acadêmicos e a detecção por sessão forte (a) ficam junto à linha do acaso ($0,50$ – $0,53$); a proximidade de rede isolada (c) é fraca e dependente de K ($0,50$ e $0,68$); e o arcabouço de correlação entre sessões completo (d) atinge $0,97$ – $0,99$. A curva densa de desempenho *vs.* K (mais valores de K) e a versão por *recall* de campanha são trabalho em curso.

5.3. Decomposição de $\Omega(S)$ por Sub-Relação

Na avaliação controlada, a massa de $\Omega(S)$ (Equação 1) que sustenta o disparo da regra é dominada por `relatedByTLSFingerprint` (peso 1,0) e pela convergência de *endpoint*, ao passo que `relatedByNetworkProximity` **não ativa** em campanhas dispersas (≈ 0 pares no mesmo /24) — confirmando a hipótese (iii) e o argumento de ponderação. As sub-relações

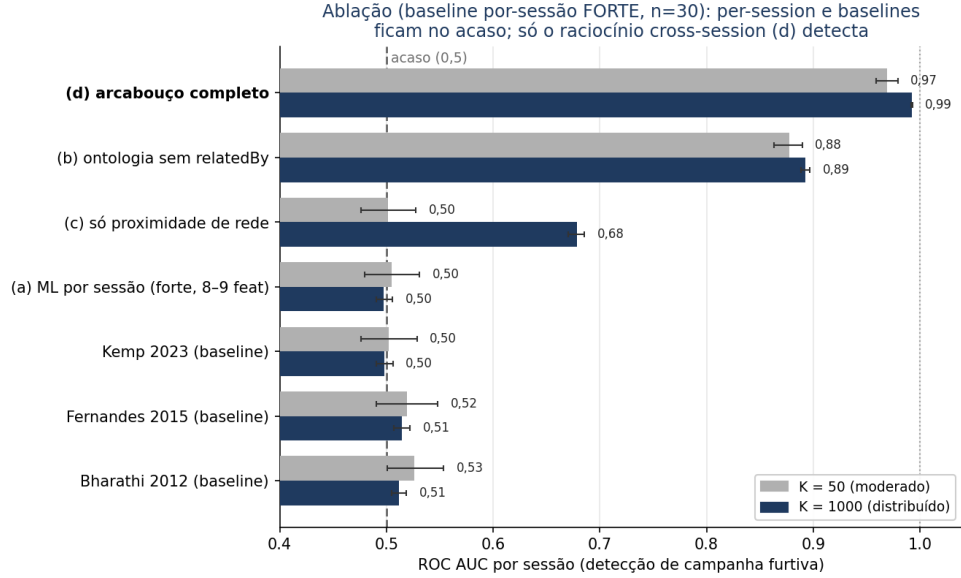


Figura 2: Ablação em campanhas furtivas: ROC AUC por sessão (IC 95%, $n = 30$) por configuração, em $K = 50$ (moderado) e $K = 1000$ (distribuído), com *baseline* por sessão forte (8–9 atributos de fluxo). *Baselines* e detecção por sessão ficam no acaso *mesmo* com atributos de fluxo completos; só o arcabouço de correlação entre sessões completo (d) detecta.

`relatedByTemporalPattern` e `relatedByPayloadSignature` não participam desta avaliação por ausência de dado correspondente a nível de sessão nos *datasets* usados, limitando a decomposição às três sub-relações instanciáveis (TLS, *endpoint*, rede).

5.4. Detecção em Dados Reais e Comparação com KLAGÉ

O teste em dados reais usa DDoS *Slowloris* do CIC-IoT2023, distribuído por 143 prefixos /24. A Tabela 2 reporta três configurações nossas mais o KLAGÉ. O contraste com a Tabela 1 é instrutivo e **reportado sem maquiagem**: enquanto um *baseline* por sessão **magro** (apenas três atributos: contagem de requisições, duração e taxa) de fato colapsa ($F_1 = 0,18$), um *baseline* por sessão **forte** (oito atributos de fluxo) *não* colapsa — atinge $F_1 = 0,900$. A razão é que o *Slowloris* real do CIC-IoT2023, ao contrário das campanhas furtivas sintéticas, deixa uma assinatura de fluxo por sessão (volume e temporização anômalos). O arcabouço de correlação entre sessões (d) atinge $F_1 = 0,911$, à frente do *baseline* forte por apenas +0,011.

Tabela 2: Detecção de DDoS *Slowloris* (CIC-IoT2023, dados reais). O *baseline* por sessão *forte* (8 atributos) não colapsa; a vantagem do raciocínio entre sessões sobre ele é marginal neste ataque convencional.

Método	F_1	Precisão	<i>Recall</i>	AUC
KLAGE (nível de nó) [12]	0,841	—	—	—
nosso (a) ML por sessão (magro, 3 atrib.)	0,179	0,691	0,103	0,551
nosso (a') ML por sessão (forte, 8 atrib.)	0,900	0,901	0,899	0,987
nosso (d) entre sessões	0,911	0,908	0,915	0,982

A leitura honesta tem três partes. Primeiro, **neste ataque real a coordenação entre sessões não é necessária**: um classificador por sessão competente já o separa, porque o ataque não é furtivo no sentido estrito (não foi calibrado para mimetizar o fluxo legítimo). Segundo, **a comparação com KLAGE é favorável mas não controlada**: nosso 0,911 supera o 0,841 publicado, e o próprio *baseline* forte (0,900) já o supera — logo a vantagem sobre o KLAGE *não* é atribuível ao raciocínio entre sessões, e ademais KLAGE classifica nós de rede enquanto nós classificamos sessões, com protocolos e cobertura de *dataset* distintos. Terceiro, **a necessidade da correlação entre sessões manifesta-se no regime furtivo distribuído** (Tabela 1), em que a detecção por sessão forte permanece no acaso ($\approx 0,50$) e só a coordenação detecta ($\approx 0,99$) — regime que os *datasets* públicos de DDoS, restritos a ataques de assinatura óbvia, não contêm. O que a abordagem em nível de sessão acrescenta sobre o estado da arte em nível de nó, de forma incondicional, é o veredicto simbólico auditável e o dano colateral mensurável.

5.5. Dano Colateral em Tráfego Legítimo

A mitigação de (a) colapsa para o controle global (limitar o *endpoint* inteiro), ao passo que (d) restringe-se ao discriminador derivado do *cluster*, tipicamente o par (*fingerprint TLS*, *padrão de endpoint*). Sobre $n = 30$ campanhas sintéticas calibradas (atacantes compartilhando um *fingerprint* TLS de *botnet* distinto, dispersos em rede, com tráfego legítimo no mesmo *endpoint*), o escopo cirúrgico derivado — que inclui o JA4 em 30/30 casos — atinge **0,00%** de tráfego legítimo [IC 95%: 0,00–0,00], contra **22,5%** [22,1–23,0] de um *rate-limit* global no *endpoint*: redução total do dano colateral.

Condição de aplicabilidade (achado honesto em dados reais). A vantagem cirúrgica *depende* de o atacante possuir um discriminador (*finger-*

print TLS ou prefixo de rede) que o tráfego legítimo no mesmo *endpoint* não compartilha. No CIC-IoT2023 essa condição **não se verifica**: o ambiente é uma LAN (atacantes e clientes legítimos no mesmo /24) e o ataque é HTTP puro (sem JA4 observável). Como consequência, sobre um *cluster* real de Slowloris dirigido a 192.168.137.1:53, o escopo derivado (*endpoint*, /24) recai sobre os mesmos legítimos, e a mitigação cirúrgica iguala-se à global (31,8% em ambos, redução nula). A redução de dano colateral, portanto, é real *quando há um discriminador de alto peso*, mas não é demonstrável nos *datasets* de laboratório atuais, que carecem dessa estrutura — o que reforça a necessidade de avaliação em tráfego de produção (TLS observável, atacantes dispersos em redes distintas dos clientes). A métrica de dano colateral, ausente da literatura acadêmica de Camada 7, é parte da contribuição metodológica.

5.6. Cadeia de Evidência e Mitigação de Escopo Derivado

Quando a regra dispara, o arcabouço emite a cadeia de evidência exportável em JSON-LD (vocabulário da ontologia, com as sub-relações ativadas, seus pesos e a Ω resultante) e em STIX 2.1 (*indicator* + *course-of-action* ligados por *mitigates*), e deriva automaticamente o escopo de mitigação a partir do conjunto mínimo de propriedades compartilhadas pelo *cluster*. O veredicto é a derivação que satisfaz a regra, não um escore interpretado a posteriori.

Avaliamos a qualidade dessas cadeias em duas dimensões sobre uma amostra de sete *clusters* de ataque reais (cinco do CICIDS2017 — Slowloris, Slowhttptest, Hulk, GoldenEye, DoS-Other — e dois do CIC-IoT2023 — Slowloris, HTTP-Flood). Em **completude**, as sete cadeias (7/7) enumeram a regra satisfeita, o tamanho do *cluster*, as sub-relações ativadas com seus pesos, o escore $\Omega(S)$ e o escopo de mitigação derivado. Em **acionabilidade**, as sete produzem um escopo concreto e não-vazio — tipicamente o par (*endpoint*, *prefixo de rede*) — diretamente aplicável como filtro. A título de exemplo, o *cluster* de DoS-Other (seis sessões, $\Omega = 10,8$) deriva o escopo {*endpoint* = 192.168.10.50:80, *srcNet24* = 172.16.0.0/24}, exportado como padrão STIX *network-traffic* $\wedge$ *ipv4-addr* ISSUBSET; cadeias completas em JSON-LD e STIX estão no material suplementar. A força do escopo depende da disponibilidade de um discriminador de peso alto (§5, dano colateral): no CICIDS2017 o atacante ocupa um /24 distinto dos clientes legítimos, tornando o escopo cirúrgico efetivo, ao passo que num ambiente LAN sem TLS o mesmo escopo recai sobre legítimos. O estudo

com analistas humanos (tempo-até-decisão, compreensão), que validaria a acionabilidade percebida, fica como trabalho futuro.

5.7. Significância Estatística

Testes pareados de Wilcoxon sobre as $n = 30$ execuções (com *baseline* por sessão forte), com correção de Bonferroni e tamanho de efeito de Cohen. No cenário distribuído ($K = 1000$), a diferença **(d)**–**(c)** é significativa com $p_{\text{Bonferroni}} = 7,5 \times 10^{-9}$ e $d = 14,1$ (efeito muito grande); a diferença **(d)**–**(a)** é significativa com $p_{\text{Bonferroni}} = 7,5 \times 10^{-9}$ e $d = 22,1$. Todos os contrastes de (d) sobre as configurações inferiores e os *baselines* são estatisticamente inquestionáveis no regime distribuído. Tamanhos de efeito desta magnitude refletem o caráter *controlado* do tráfego sintético (separação quase perfeita) e não devem ser lidos como expectativa de desempenho em campo (§5, Limitações).

5.8. Limitações

As limitações principais devem ser declaradas explicitamente:

1. **Vantagem regime-específica:** para ataques *single-source* de alto volume (Cenário A), métodos baseados em limiares estatísticos por IP ou por sessão alcançam desempenho comparável; o ganho marginal do raciocínio entre sessões é pequeno nesse regime. O ganho cresce com o grau de distribuição da campanha. Este artigo não substitui defesas volumétricas; complementa-as.
2. **Dependência de identificação de sessão e identidade:** a abordagem assume capacidade de extrair sessões, identidades e *fingerprints* TLS dos eventos de tráfego. Em ambientes onde essa instrumentação é parcial ou ruidosa, o desempenho degrada. A adoção em escala de *Encrypted ClientHello* (ECH) na padronização TLS 1.3 pode tornar JA4 inobservável a partir do operador da aplicação; nesse cenário, sinais alternativos baseados em metadata de TLS (TCP *fingerprint*, JA4T, timing) ou em comportamento HTTP precisam compensar.
3. **Adversidade adaptativa:** atacantes sofisticados podem (i) forjar JA4 via bibliotecas como `curl-impersonate`, que reproduzem o *handshake* TLS de navegadores reais; (ii) introduzir *jitter* aleatório no padrão temporal entre nós da *botnet*; (iii) rotacionar identidades a cada sessão; e (iv) randomizar *payload* e *User-Agent*. A família ponderada de sub-relações é desenhada precisamente para tolerar quebra parcial: quando

JA4 é forjado, identidade reaproveitada e padrão temporal carregam; quando o padrão temporal é jittered, JA4 e identidade carregam. A quebra simultânea de três ou mais sinais de peso alto, contudo, degrada o arcabouço para próximo de desempenho aleatório. Esse regime de adversidade sofisticada representa um aumento substancial no custo operacional da campanha (cada sinal quebrado exige infraestrutura adicional do atacante) e a avaliação dirigida contra atacante adaptativo é direção de extensão prioritária (§6).

4. **Custo de manutenção do grafo** em produção, sensibilidade ao parâmetro W (janela operacional). A latência média da regra é medida em §5, e a escolha de OWL 2 RL como perfil de *reasoning* mantém o *throughput* em ordem linear para volumes de tráfego de aplicação web típicos; a escalabilidade para tráfego de CDN com milhões de requisições por segundo requer particionamento horizontal não explorado neste trabalho.
5. **Generalização para protocolos além de HTTP/1.1 e variantes Slow HTTP DoS clássicas:** a ontologia atual cobre a família de Slowloris e descendentes diretos sobre HTTP/1.1; a extensão para ataques HTTP/2 modernos (Rapid Reset, CONTINUATION Flood) e para outros protocolos de aplicação (DNS, gRPC) é direção de extensão imediata.
6. **Natureza controlada da avaliação sintética:** na avaliação sintética, a campanha é gerada com sinais de coordenação (JA4, *endpoint*, prefixo) que são exatamente os medidos pela configuração (d), e cada sessão atacante tem seus atributos por sessão — inclusive os de fluxo (volume, pacotes, intervalo entre requisições) — amostrados das distribuições do tráfego *benigno real* (calibradas sobre ~322 mil sessões legítimas). Em consequência, a não-separabilidade por sessão observada na Tabela 1 *não* é artefato de um *baseline* enfraquecido: um *Random Forest* com todos os 8–9 atributos de fluxo permanece no acaso. Em contrapartida, esse mesmo mimetismo é imposto por construção, de modo que o resultado demonstra o *mecanismo* sob a hipótese de mimetismo por sessão perfeito — que a estrutura de correlação entre sessões, quando presente, é capturada e que a detecção por sessão a ignora — e não constitui prova de desempenho sobre uma captura real desse regime. Um teste de isolamento sustenta que o arcabouço responde ao sinal genuíno e não a um artefato: variando-se a fração de origens que compartilham o *fingerprint* TLS, com diversidade de JA4

legítimo realista, a detecção baseada *apenas* no sinal de JA4 acompanha monotonicamente essa fração (AUC de 1,00 a 0,41), enquanto o arcabouço completo permanece robusto por redundância (a convergência de *endpoint* sustenta a detecção quando o JA4 é removido).

7. **Datasets públicos não exercitam o regime-alvo:** em *datasets* reais públicos de DDoS, um classificador por sessão forte já separa os ataques disponíveis (CICIDS2017 e CIC-IoT2023: Hulk, GoldenEye, Slowloris, Slowhttptest, HTTP-Flood alcançam $AUC \geq 0,98$ por sessão, com ganho do raciocínio entre sessões marginal), porque são ataques de assinatura de fluxo evidente, não campanhas furtivas calibradas para mimetizar o tráfego legítimo. A vantagem do raciocínio entre sessões é, portanto, demonstrada *apenas* no regime furtivo distribuído sintético. Validar a abordagem sobre tráfego furtivo distribuído *capturado* (idealmente com TLS observável e atacantes em redes distintas dos clientes) — que não existe em *benchmark* público — é a direção experimental mais importante.
8. **Cobertura de dados reais e natureza dos *datasets*:** a validação em dados reais cobre um *dataset* (CIC-IoT2023) e um ataque (DDoS Slowloris). Além disso, os *datasets* CIC são gerados em *testbed* de laboratório, não amostrados de tráfego de produção; a generalização para múltiplos *datasets* (incluindo RT-IoT2022 e famílias fora do CIC) e para tráfego real anonimizado é trabalho prioritário.
9. **Calibração dos pesos não realizada empiricamente:** o *grid search* dos pesos w_i satura no tráfego sintético padrão (qualquer combinação separa perfeitamente), de modo que os pesos derivam do argumento de resistência à evasão, não de otimização sobre dados. Uma calibração empírica significativa requer conjunto de validação com sinais parciais e conflitantes.
10. **Comparação com KLAGÉ não controlada:** a comparação é de ordem de grandeza, não um confronto direto — diferem granularidade (nó *vs.* sessão), protocolo de avaliação e cobertura de *dataset*. Ademais, no mesmo ataque o nosso *baseline* por sessão forte ($F_1 = 0,900$) já supera o KLAGÉ (0,841), de modo que a dianteira do arcabouço completo (0,911) sobre o KLAGÉ *não* é atribuível ao raciocínio entre sessões. Reproduzir o KLAGÉ sob o mesmo protocolo é extensão necessária para qualquer afirmação de superioridade.
11. **Validação da explicação limitada à análise estrutural:** as cadeias de evidência foram avaliadas sobre *clusters* reais detectados quanto a

completude e acionabilidade estrutural (7/7; §5), mas a acionabilidade *percebida* — um estudo com analistas humanos medindo tempo-até-decisão e compreensão — não foi conduzida e permanece trabalho futuro. O raciocínio simbólico (SPARQL/SWRL) foi exercitado em escala reduzida; sua execução sobre o grafo completo em produção fica como extensão.

6. Conclusão

Este artigo propôs um arcabouço de grafos de conhecimento centrado na sessão HTTP como entidade ontológica de primeira classe, com quatro componentes principais: (i) ontologia OWL alinhada a STIX 2.1 e MITRE ATT&CK, com a família `SlowHTTPDoSFamily` e a família ponderada `relatedTo` de seis sub-propriedades tipadas; (ii) *pipeline* de construção do grafo em tempo de execução, com cada sub-relação `relatedBy` instanciada independentemente; (iii) regra de detecção `CoordinatedHTTPFlood` formulada em SPARQL/SWRL sobre a soma ponderada das sub-relações, com cadeia de evidência simbólica acoplada à derivação automática de escopo de mitigação; (iv) avaliação parametrizada pelo grau de distribuição, com ablação por subgrupo de sinais e métrica de dano colateral em tráfego legítimo. A defensabilidade da abordagem se sustenta sobre o reconhecimento explícito de que botnets modernas distribuem agressivamente em ASN e prefixo de IP, o que torna a proximidade de rede um sinal auxiliar e atribui o peso decisivo aos sinais de *fingerprint* TLS, identidade reaproveitada e padrão temporal.

A avaliação preliminar sustenta a tese central e delimita honestamente seu alcance. Em campanhas furtivas distribuídas, a detecção por sessão opera próxima do acaso *mesmo* com um classificador forte (8–9 atributos de fluxo) e com os *baselines* de aprendizado de máquina, enquanto o arcabouço completo as detecta de forma consistente (ROC AUC $\approx 0,50$ *vs.* $\approx 0,99$), com vantagem sobre o subgrupo de proximidade de rede estatisticamente significativa ($p < 0,01$ após Bonferroni; $d = 14,1$). O ganho é, contudo, *regime-específico*, e isto deve ser dito sem rodeios: em ataques reais convencionais — os únicos presentes nos *datasets* públicos — um classificador por sessão forte já basta, e o raciocínio entre sessões agrega pouco; a vantagem decisiva manifesta-se quando a campanha é distribuída *e* furtiva, regime ausente dos *benchmarks* atuais e que motiva tanto o gerador calibrado quanto a prioridade de avaliação em tráfego de produção. A mitigação de escopo derivado elimina o dano colateral sobre o tráfego legítimo (22,5% $\rightarrow$ 0%) quando há um dis-

criminator de peso alto observável, condição que os *datasets* de laboratório disponíveis (LAN, HTTP não cifrado) não oferecem e que remete à necessidade de avaliação em tráfego de produção. A calibração empírica dos pesos w_i permaneceu inconclusiva sobre os dados sintéticos (a separação satura), de modo que os pesos reportados decorrem do argumento de resistência à evasão, não de otimização — a calibração sobre tráfego real é trabalho em aberto.

Direções futuras imediatas incluem: (i) a extensão da ontologia e da regra de detecção para a categoria adjacente de *ataques HTTP/2 modernos* (Rapid Reset/CVE-2023-44487, CONTINUATION Flood, MadeYouReset), que requer a introdução de sub-relações específicas do plano de *stream* (notadamente `relatedByStreamCancellationPattern`); (ii) a operacionalização experimental das classes `CredentialStuffing` (subclasse de `LoginFlood`) e `CoordinatedAPIAbuse`, já formalizadas na ontologia mas fora do escopo experimental atual, que reaproveitam a mesma família `relatedTo` ponderada; (iii) a extensão para outros protocolos de aplicação (DNS, TLS *handshake*, gRPC); (iv) a integração com plataformas SOAR para resposta automatizada a partir da cadeia de evidência exportada; (v) a avaliação em ambientes de produção com dados reais anonimizados, sob aprovação ética; (vi) estudos com analistas de segurança para validação operacional das cadeias de evidência geradas; e (vii) a investigação do efeito de *fingerprints* TLS ofuscados (atacantes que randomizam ativamente o *handshake*) sobre o desempenho do arcabouço, com hipótese a priori de que sinais de peso alto remanescentes (identidade reaproveitada, padrão temporal) compensam parcialmente a perda.

Referências

- [1] N. Tripathi, N. Hubballi, Application layer denial-of-service attacks and defense mechanisms: A survey, ACM Computing Surveys 54 (4) (2021) 1–33. doi:10.1145/3448291.
- [2] Cloudflare, HTTP/2 zero-day vulnerability results in record-breaking DDoS attacks, Cloudflare Blog (Oct. 2023).
URL <https://blog.cloudflare.com/zero-day-rapid-reset-http2-record-breaking-ddos/>
- [3] Google Cloud, How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack, Google Cloud Blog, google reports record-breaking peak of 398 million requests per second mitigated (Oct. 2023).

URL <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>

- [4] MITRE Corporation, CVE-2023-44487: HTTP/2 rapid reset attack, National Vulnerability Database, disclosed October 10, 2023; coordinated disclosure across multiple HTTP/2 implementations (2023). URL <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [5] Cloudflare, Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report, Cloudflare Blog, reports 6,500+ hyper-volumetric attacks in Q2 2025 (avg. 71/day); HTTP DDoS grew 129% year-over-year (2025). URL <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [6] Cloudflare, Targeted by 20.5 million DDoS attacks, up 358% year-over-year: Cloudflare’s 2025 Q1 DDoS threat report, Cloudflare Blog (2025). URL <https://blog.cloudflare.com/ddos-threat-report-for-2025-q1/>
- [7] E. Cambiaso, G. Papaleo, G. Chiola, M. Aiello, Slow DoS attacks: Definition and categorisation, in: International Journal of Trust Management in Computing and Communications, Vol. 1, Inderscience, 2013, pp. 300–319. doi:10.1504/IJTMCC.2013.056440.
- [8] C. Kemp, C. Calvert, T. M. Khoshgoftaar, J. L. Leevy, An approach to application-layer DoS detection, Journal of Big Data 10 (1) (2023) 22. doi:10.1186/s40537-023-00699-3.
- [9] R. Bharathi, R. Sukanesh, A PCA based framework for detection of application layer DDoS attacks, WSEAS Transactions on Information Science and Applications 9 (12) (2012) 389–398.
- [10] G. Fernandes Jr., J. J. P. C. Rodrigues, M. L. Proença Jr., Autonomous profile-based anomaly detection system using principal component analysis and flow analysis, Applied Soft Computing 34 (2015) 513–525. doi:10.1016/j.asoc.2015.05.019.
- [11] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, L. Fernández-Sanz, A survey and meta-analysis of application-layer distributed denial-of-service attack, International Journal of Communication Systems 33 (18) (2020) e4603. doi:10.1002/dac.4603.

- [12] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, F. Marozzo, Enhancing network security using knowledge graphs and large language models for explainable threat detection, *Future Generation Computer Systems* 176 (2026) 108160, published online October 2025; received 29 April 2025; accepted 20 September 2025. doi:10.1016/j.future.2025.108160.
- [13] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, Y. Zhou, Recent progress of using knowledge graph for cybersecurity, *Electronics* 11 (15) (2022) 2287. doi:10.3390/electronics11152287.
- [14] Y. Jia, Y. Qi, H. Shang, R. Jiang, A. Li, A practical approach to constructing a knowledge graph for cybersecurity, *Engineering* 4 (1) (2018) 53–60. doi:10.1016/j.eng.2018.01.004.
- [15] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, P. Varalakshmi, Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions, in: 2024 4th Asian Conference on Innovation in Technology (ASIANCON), IEEE, 2024. doi:10.1109/ASIANCON62057.2024.10838144.

Apêndice A. Detalhes da Ontologia

A ontologia OWL (RDF/XML) modela a classe `ApplicationSession` e a família `relatedTo` com as seis sub-propriedades tipadas, cada uma anotada com seu peso de coordenação (`coordinationWeight`): `relatedByTLSPFingerprint` e `relatedByReusedIdentity` (1,0), `relatedByTemporalPattern` (0,9), `relatedByPayloadSignature` e `relatedByEndpointConvergence` (0,6) e `relatedByNetworkProximity` (0,3). É disponibilizada em formato RDF/XML no repositório do projeto.

Apêndice B. Reprodutibilidade

A implementação de referência é disponibilizada como código aberto, sob licença permissiva, organizada por etapa experimental (pipeline de extração, gerador sintético calibrado, ablação e *baselines*, execução estatística, comparação com o estado da arte, e os módulos de raciocínio simbólico e de evidência/mitigação), com *seeds* fixas, *Makefiles* de orquestração e artefatos versionados (figuras, distribuições calibradas e resultados agregados). Cada etapa reexecuta por um único comando e reproduz os números reportados.